

MEHFOOZ () / SAFEPATH — PRODUCT REQUIREMENT DOCUMENT (PRD)

Version: 3.2.0

Document Owner: Engineering & Product Architecture Team

Status: Approved / Production-Ready

Classification: Public Safety & Privacy-Preserving Technology

Target Region: Punjab, Pakistan (with scalable modularity for South Asia)

Last Updated: September 2026

Table of Contents

1. Executive Summary & System Vision
 2. System Architecture & Technology Stack
 3. Security, Authentication & Zero-Knowledge Architecture
 4. Functional Requirements (Core Pillars)
 - Module 1: Stealth Weather Disguise Cover
 - Module 2: Safe Corridor Pedestrian Navigation
 - Module 3: Grounded AI Legal Advisor & Hybrid RAG Engine
 - Module 4: Zero-Knowledge Incident Vault
 - Module 5: Destination Check-In Timer
 - Module 6: Crisis SOS Dispatch Engine
 - Module 7: Complaint Builder & 9-Department Routing Engine
 5. Non-Functional Requirements & Hardening
 6. User Personas & User Journeys
 7. Project Directory Structure & Component Registry
 8. Installation & Vercel Deployment
 9. Compliance & Legal Framework (Punjab, Pakistan)
-

1. Executive Summary & System Vision

1.1 Executive Summary

Mehfooz (— “protected” in Urdu) is a client-first, privacy-preserving women’s safety ecosystem designed specifically for the ground socio-legal realities of Punjab, Pakistan. It integrates six critical safety pillars into a single application disguised behind an authentic meteorological weather interface:

1. **Stealth Weather Cover:** A realistic weather disguise with dual triggers (double-tap and 2.5s long-press), numeric PIN entry, and instant **Escape** key quick-exit handler.
2. **Safe Corridor Navigation:** Algorithmic pedestrian routing weighted by Street Lighting Density, Safe City CCTV camera clusters, commercial

footfall, and verified safe havens.

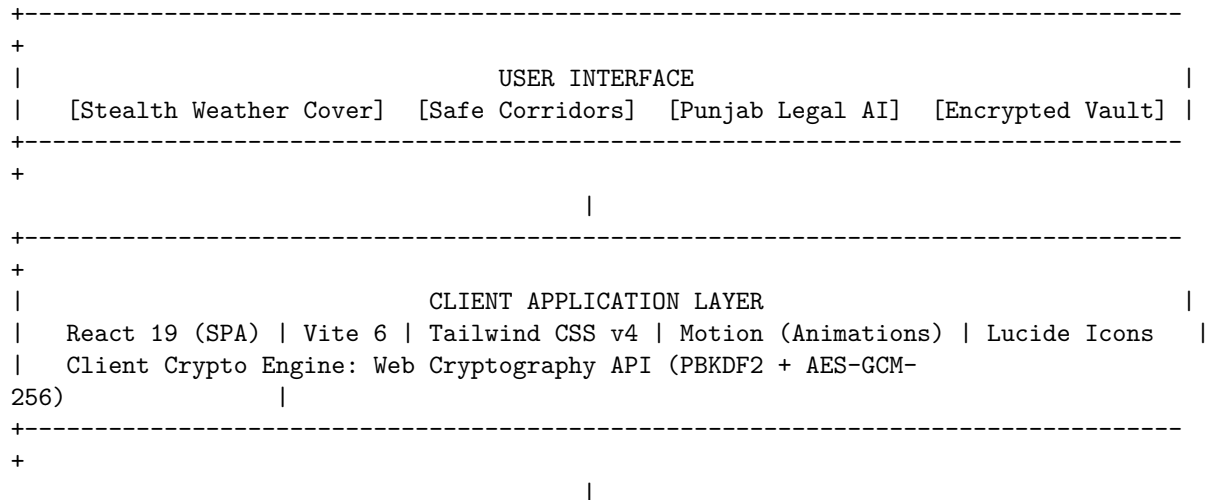
3. **Punjab AI Legal Advisor:** A grounded Retrieval-Augmented Generation (RAG) statutory legal AI trained on the *Punjab Protection of Women Against Violence Act (PPWVA 2016)*, *PECA Cyber Laws (2016)*, and relevant *Pakistan Penal Code (PPC)* provisions.
4. **Zero-Knowledge Incident Vault:** Client-side Web Crypto AES-GCM-256 encrypted evidence locker storing audio notes, photographs, and harassment timestamps locally.
5. **Silent Destination Check-In:** Automated failsafe journey timers backed by a Supabase `pg_cron` monitor dispatching GPS coordinates and SMS alerts to guardian circles upon missed deadlines.
6. **Crisis SOS Engine:** Emergency one-tap coordination connecting users directly with Punjab Police Safe City (15), Punjab Commission on the Status of Women (PCSW 1043), and Rescue 1122.

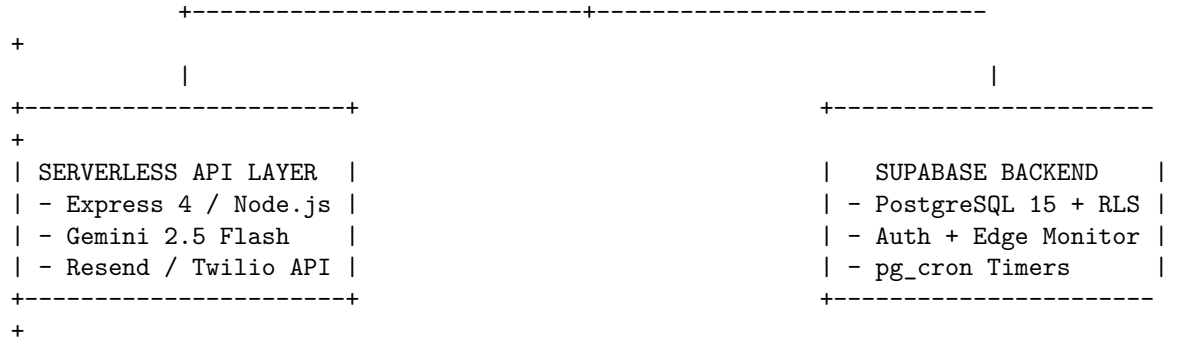
[!IMPORTANT] **Privacy First:** Plaintext evidence or unencrypted personal data never touches cloud servers. All encryption keys are derived solely in volatile browser RAM using Web Crypto PBKDF2 + AES-GCM-256.

1.2 Vision Statement

To eliminate fear in mobility and legal ambiguity for women and vulnerable citizens through discreet, accessible, and privacy-preserving technology that bridges immediate physical protection with long-term statutory legal empowerment.

2. System Architecture & Technology Stack





2.1 Technology Stack Matrix

Component	Technology	Rationale & Specification
Frontend Framework	React 19.0.1 + TypeScript 5.8	High type-safety, modular component tree, 0 compilation errors
Build System	Vite 6.2.3	Ultra-fast bundling, minimal bundle overhead, rapid HMR
Styling Engine	Tailwind CSS v4.1	Responsive utility classes, custom design tokens, theme switching
Animation Engine	Motion 12.23 (motion/react)	Smooth transition states, gesture handling, modal sheet physics
Client Encryption	Web Crypto API (SubtleCrypto)	Native browser engine (PBKDF2 key derivation + AES-GCM-256)
Server Runtime	Node.js 24 + Express 4.21	Security headers (Helmet), Rate Limiting (express-rate-limit)
AI Legal RAG Engine	Google Gemini 2.5 Flash (@google/genai)	Bounded function-calling loop, RAG vector retrieval, citations
Database / Auth	Supabase PostgreSQL 15	Row-Level Security (RLS), Native Supabase Auth verification
Communication	Resend Email SDK + Twilio SMS	Transactional department emails and emergency SMS alerts

3. Security, Authentication & Zero-Knowledge Architecture

3.1 Stealth Access & Disguise Protocol

- **Default Launch State:** The application launches into the **Weather Forecast UI** (`WeatherCover.tsx`).
- **Stealth Trigger 1 (Tap):** Double-tap on the temperature numeral (23°) triggers the numeric PIN modal.
- **Stealth Trigger 2 (Hold):** Long-press (2.5 seconds) on the background weather card displays a green progress bar followed by automatic unlock.
- **Quick Exit Escape Trigger:** Pressing `Esc` on desktop or double-tapping the top logo immediately terminates the session and returns to the weather cover screen.

[!NOTE] Per-user stealth PINs are set in the user profile (demo default: 1520). Long-press recovery provides a failsafe unlock mechanism without universal hardcoded backdoors.

3.2 Native Supabase Auth & Email Confirmation Protocol

To maintain zero security compromises, forged email confirmation overrides have been removed:

1. User submits registration via `signUpUser()` in `src/utils/auth.ts`.
2. `supabase.auth.signUp()` dispatches an official HTML email containing a unique confirmation link (`{{ .ConfirmationURL }}`).
3. Clicking the link verifies the token in Supabase and sets `email_confirmed_at` in `auth.users`.
4. Unconfirmed users attempting to sign in are blocked with: *“Please confirm your email address first (check your inbox).”*

3.3 Account Enumeration Defense & Obfuscation

When a user attempts to register with an email address already registered in Supabase:

1. Supabase returns a `User already registered` error.
2. The client intercepts this error in `friendlyAuthError()` without sending duplicate emails or modifying profiles.
3. Displays the obfuscated error notice: **“This email already has an account linked. Please sign in instead.”**

3.4 Client-Side First-Time Onboarding Token Architecture

To ensure the onboarding setup walkthrough appears **only** upon the user’s very first login post-email-confirmation:

- **Token Check:** `hasUserCompletedOnboarding(identifier)` checks `localStorage` for `mehfooz_onboarding_token_{user_id_or_email}`.
- **First-Time Login:** If no token is found, `needsOnboarding` is set to `true`, displaying `OnboardingModal.tsx`.
- **Token Completion:** Completing step 6/7 executes `markUserOnboardingCompleted(identifier)`, writing `'completed'` to `localStorage`.
- **Subsequent Logins:** On all future logins, the token match bypasses onboarding completely with zero server database overhead.

3.5 Client-Side Web Crypto AES-GCM-256 Vault Architecture

```
// PBKDF2 Key Derivation + AES-GCM-256 Encryption
const salt = crypto.getRandomValues(new Uint8Array(32));
const keyMaterial = await crypto.subtle.importKey(
  'raw', new TextEncoder().encode(userPin), 'PBKDF2', false, ['deriveKey']
);
const aesKey = await crypto.subtle.deriveKey(
  { name: 'PBKDF2', salt, iterations: 100000, hash: 'SHA-256' },
  keyMaterial,
  { name: 'AES-GCM', length: 256 },
  false, ['encrypt', 'decrypt']
);
```

4. Functional Requirements (Core Pillars)

Module 1: Stealth Weather Disguise Cover

- **FR-1.1:** Render realistic weather data (Day, Night, and Sunrise themes).
- **FR-1.2:** Support 6 weather stations (Lahore, Islamabad, Murree, Karachi, Florence, Tuscany).
- **FR-1.3:** Provide 24-hour forecast, 7-day outlook, AQI meter, humidity, wind velocity, and UV index.
- **FR-1.4:** Numeric PIN keypad with wrong-PIN shake feedback and automatic input masking.

Module 2: Safe Corridor Pedestrian Navigation

- **FR-2.1:** Interactive corridor map displaying safety ratings ($A+$, A , B , C).
- **FR-2.2:** Multidimensional Safety Score calculation:

$$\text{Safety Score} = 0.35 \times \text{Lighting} + 0.30 \times \text{CCTV} + 0.20 \times \text{Safe Havens} + 0.15 \times \text{Crowd Density}$$

- **FR-2.3:** Safe Haven Business Pins (Pharmacies, 24/7 fuel stations, police service centers).
- **FR-2.4:** Live audit submission allowing commuters to flag broken street lights or harassment hotspots.

Module 3: Grounded AI Legal Advisor & Hybrid RAG Engine

- **FR-3.1:** Bilingual (English/Urdu) voice-enabled chat powered by Gemini 2.5 Flash function-calling loop.
- **FR-3.2:** Grounded statutory legal RAG index containing 34 Punjab statutes:
 - *PPWVA 2016*: Section 4 (Protection Orders), Section 5 (Residence Orders), Section 6 (Monetary Orders).

- *PECA 2016*: Section 20 (Dignity), Section 21 (Non-Consensual Images), Section 24 (Cyber Stalking).
- *Pakistan Penal Code (PPC)*: Section 354A, Section 509 (Insulting Modesty).
- **FR-3.3**: Hybrid RAG Scoring Formula:

$$\text{Score} = 0.60 \times \text{CosineSimilarity}(\vec{v}_{\text{query}}, \vec{v}_{\text{doc}}) + 0.40 \times \text{BM25KeywordScore}$$

Module 4: Zero-Knowledge Incident Vault

- **FR-4.1**: Create incident records categorized by type (Physical Stalking, Workplace Harassment, Cyber Extortion, Domestic Dispute).
- **FR-4.2**: Client-side encrypted audio recorder and photo locker using Web Crypto AES-GCM-256.
- **FR-4.3**: Official PDF court docket generator using jsPDF with SHA-256 checksum verification.

Module 5: Destination Check-In Timer

- **FR-5.1**: User sets journey duration (e.g., 20 mins) and destination location.
- **FR-5.2**: Visual countdown timer with a 2-minute Grace Period notification.
- **FR-5.3**: Automatic SMS dispatch with live Google Maps coordinates if check-in fails.

Module 6: Crisis SOS Dispatch Engine

- **FR-6.1**: One-touch hold-to-activate (2-second countdown) emergency beacon.
- **FR-6.2**: Direct telephony links to Police 15, PCSW 1043, and Rescue 1122.
- **FR-6.3**: Multi-guardian Twilio SMS transmission with live GPS coordinates.

Module 7: Complaint Builder & 9-Department Routing Engine

Automated complaint dispatch routing to concerned Punjab government bodies:

Channel ID	Target Department	Helpline / Email	API / Phone
police_support	Punjab Safe Cities Authority (PSCA)	complaint@psca.gov.pk	15pk
pcsw_helpline	Punjab Commission on Status of Women	complaint@pcsw.punjab.gov.pk	1043

Channel ID	Target Department	Helpline / Email	API / Phone
fospah	Federal Ombudsperson (FOSPAH)	complaint@mohtasib.gov.pk	995119202078
workplace_ombudspe	ombudsperson Punjab	complaint@ombudspersonpunjab.gov.pk	9951199245025
legal_aid	AGHS Legal Aid Cell	aghslegalaid@gmail.com	995119342 35763234
shelter	Dar-ul-Aman (Social Welfare)	darulaman@socialwelfare.punjab.gov.pk	995119342 35763234
cyber_safety	Digital Rights Foundation (DRF)	helpdesk@digitalrightsfoundation.pk	995119342 35763234

5. Non-Functional Requirements & Hardening

Parameter	Specification / Metric
Emergency Latency	SOS trigger initiates telephony link within < 100 ms of touch release
Cold Start	App load time < 1.2 s on 3G/4G mobile networks
Encryption Strength	AES-GCM-256 authenticated encryption with 96-bit IV, 128-bit tag, PBKDF2 (100k iter)
Security Headers	Helmet protection (<code>nosniff</code> , XSS block, CSP, strict referrer policy)
Rate Limiting	<code>express-rate-limit</code> active on all <code>/api/*</code> endpoints
Input Sanitization	Null-byte filtering, script injection filters, max 3,000 char query limits
TypeScript Integrity	0 compilation errors (<code>tsc --noEmit</code> exit code 0)

6. User Personas & User Journeys

Persona A: Ayesha (University Student, Lahore)

- **Context:** Commutes on public transit and walking routes along Canal Road after evening classes.

- **User Story:** *“As a student commuting at dusk, I want to view verified well-lit walking corridors so that I can avoid unmonitored dark alleys.”*

Persona B: Fatima (Corporate Employee, Rawalpindi)

- **Context:** Facing workplace harassment and cyber blackmail from an ex-colleague.
- **User Story:** *“As a survivor of harassment, I want to store dated screenshots and audio memos in an encrypted vault disguised as a weather app so that my phone cannot be compromised by family or peers.”*

Persona C: Zainab (Freelancer, Multan)

- **Context:** Needs to understand legal remedies under Punjab law without paying high retainer fees to a lawyer.
- **User Story:** *“As a citizen, I want to ask plain-language questions about domestic protection orders and get exact Punjab legal section numbers and draft letters.”*

7. Project Directory Structure & Component Registry

MehfoozAi/	
src/	# Client-side React SPA
components/	
common/	# Shared: MehfoozLogo, OfflineIndicator, PWAIInstallButton
landing/	# AbstractArt, HeroAnimatedLogo, PhoneMockupShowcase
ui/	# button, card, badge, primitives, star-
rating	
weather/	# LandscapeIllustration, WeatherIcons
ActiveAlerts.tsx	# Live street safety hazard warnings
AgentActionCard.tsx	# AI agent pending action confirmation cards
AuthModal.tsx	# Dual-mode authentication (Supabase / Local)
ComplaintBuilder.tsx	# Multi-step complaint form with department routing
CrisisModal.tsx	# Emergency SOS modal
IncidentVault.tsx	# Encrypted evidence locker
LegalAssistant.tsx	# AI Legal Advisor chat
Navigation.tsx	# Navigation bars
OnboardingModal.tsx	# First-time user setup walkthrough
SafeNavigation.tsx	# Leaflet/OSM safe corridor map
SilentCheckIn.tsx	# Destination check-in timer
WeatherCover.tsx	# Stealth weather disguise
...	
utils/	
auth.ts	# Supabase Auth & client onboarding tokens
crypto.ts	# AES-GCM-256 Web Crypto encryption helpers

hybridRetriever.ts	# 60% Vector + 40% BM25 scoring engine
orchestrator.ts	# Intent classification & legal corpus RAG
...	
App.tsx	# Root component & tab router
types.ts	# All TypeScript interfaces
server/	# Server-side modules
agent/	# Gemini Bounded Agent System (15 files)
departmentRouting.ts	# 9 Punjab government departments dispatcher
email.ts	# Resend email SDK
sms.ts	# Twilio SMS emergency gateway
supabaseServer.ts	# Supabase admin client & JWT middleware
server.ts	# Express server entry point
api/index.ts	# Vercel serverless entry point
vercel.json	# Vercel deployment configuration
README.md	# Project documentation

8. Installation & Vercel Deployment

8.1 Prerequisites

- Node.js (v18.0.0 or higher)
- npm or yarn

8.2 Local Development

```
# 1. Clone the repository
git clone https://github.com/MudassarAbrar/MehfoozAi.git
cd MehfoozAi

# 2. Install dependencies
npm install

# 3. Start development server (Vite + Express)
npm run dev
```

8.3 Production Build

```
# Compile and verify TypeScript + Vite bundle
npm run build
```

9. Compliance & Legal Framework (Punjab, Pakistan)

[!TIP] **Legal Adherence:** - PPWVA 2016: Direct compliance with Section 4–8 provisions for violence tracking and Violence Against

Women Center (VAWC) referrals. - **PECA 2016:** Section 20, 21, and 24 compliance for digital evidence formatting for FIA Cyber Crime submission. - **Data Minimization:** Zero-log telemetry on user locations and zero unencrypted server data storage.